

ACME Cloud Infrastructure Security & Governance Policy

Standard Reference: SOC 2 (CC6.1, CC6.6, CC7.1, A1.2) & ISO/IEC 27001:2022 (A.8.1, A.8.24)

1. Object Storage Security (S3)

1.1 Control ID: SEC-S3-001 (Data Encryption)

All Amazon S3 storage buckets must enforce server-side encryption with AWS KMS or AES-256. Unencrypted buckets are strictly prohibited.

1.2 Control ID: SEC-S3-002 (Public Access Prevention)

Public read and write access must be completely blocked on all production and internal S3 buckets. The `block_public_acls` and `block_public_policy` properties must evaluate to true.

1.3 Control ID: SEC-S3-003 (Data Lifecycle & Versioning)

Where the bucket classification is tagged as 'regulated_data', bucket versioning must be enabled ('Enabled') to protect against accidental deletion.

2. Database Storage & High Availability (RDS)

2.1 Control ID: SEC-RDS-001 (Storage Encryption)

All Amazon RDS database instances must have storage encryption enabled (`storage_encrypted == true`) using customer-managed or AWS-managed KMS keys.

2.2 Control ID: SEC-RDS-002 (Production High Availability)

For all RDS instances operating in the 'production' environment, Multi-AZ deployment (`multi_az`) must be set to true.

2.3 Control ID: SEC-RDS-003 (Automated Backup Retention)

Automated database backup retention period (`backup_retention_days`) must be greater than or equal to 7 days.

3. Virtual Compute Instances (EC2)

3.1 Control ID: OPS-EC2-001 (Compute Utilization & Capacity)

Under baseline operations, Amazon EC2 instances must maintain average `cpu_utilization` below 85 percent.

3.2 Control ID: SEC-EC2-002 (IMDSv2 Enforce Token Access)

All running EC2 instances must enforce Instance Metadata Service Version 2 (`http_tokens == 'required'`) to prevent SSRF vulnerabilities.